Low SQL Injection (Blind) Source

```php
<?php

if( isset( $_GET[ 'Submit' ] ) ) {
    // Get input
    $id = $_GET[ 'id' ];
    $exists = false;

    switch ($_DVWA['SQLI_DB']) {
        case MYSQL:
            // Check database
            $query  = "SELECT first_name, last_name FROM users WHERE user_id = '$id';";
            try {
                $result = mysqli_query($GLOBALS["___mysqli_ston"],  $query ); // Removed 'or die' to suppress mysql errors
            } catch (Exception $e) {
                print "There was an error.";
                exit;
            }

            $exists = false;
            if ($result !== false) {
                try {
                    $exists = (mysqli_num_rows( $result ) > 0);
                } catch(Exception $e) {
                    $exists = false;
                }
            }
            ((is_null($___mysqli_res = mysqli_close($GLOBALS["___mysqli_ston"]))) ? false : $___mysqli_res);
            break;
        case SQLITE:
            global $sqlite_db_connection;

            $query  = "SELECT first_name, last_name FROM users WHERE user_id = '$id';";
            try {
                $results = $sqlite_db_connection->query($query);
                $row = $results->fetchArray();
                $exists = $row !== false;
            } catch(Exception $e) {
                $exists = false;
            }

            break;
    }

    if ($exists) {
        // Feedback for end user
        echo '<pre>User ID exists in the database.</pre>';
    } else {
        // User wasn't found, so the page wasn't!
        header( $_SERVER[ 'SERVER_PROTOCOL' ] . ' 404 Not Found' );

        // Feedback for end user
        echo '<pre>User ID is MISSING from the database.</pre>';
    }

}

?>
```

High SQL Injection (Blind) Source

```php
<?php

if( isset( $_COOKIE[ 'id' ] ) ) {
    // Get input
    $id = $_COOKIE[ 'id' ];
    $exists = false;

    switch ($_DVWA['SQLI_DB']) {
        case MYSQL:
            // Check database
            $query  = "SELECT first_name, last_name FROM users WHERE user_id = '$id' LIMIT 1;";
            try {
                $result = mysqli_query($GLOBALS["___mysqli_ston"],  $query ); // Removed 'or die' to suppress mysql errors
            } catch (Exception $e) {
                $result = false;
            }

            $exists = false;
            if ($result !== false) {
                // Get results
                try {
                    $exists = (mysqli_num_rows( $result ) > 0); // The '@' character suppresses errors
                } catch(Exception $e) {
                    $exists = false;
                }
            }

            ((is_null($___mysqli_res = mysqli_close($GLOBALS["___mysqli_ston"]))) ? false : $___mysqli_res);
            break;
        case SQLITE:
            global $sqlite_db_connection;

            $query  = "SELECT first_name, last_name FROM users WHERE user_id = '$id' LIMIT 1;";
            try {
                $results = $sqlite_db_connection->query($query);
                $row = $results->fetchArray();
                $exists = $row !== false;
            } catch(Exception $e) {
                $exists = false;
            }

            break;
    }
```

```php
    if ($exists) {
        // Feedback for end user
        echo '<pre>User ID exists in the database.</pre>';
    }
    else {
        // Might sleep a random amount
        if( rand( 0, 5 ) == 3 ) {
            sleep( rand( 2, 4 ) );
        }

        // User wasn't found, so the page wasn't!
        header( $_SERVER[ 'SERVER_PROTOCOL' ] . ' 404 Not Found' );

        // Feedback for end user
        echo '<pre>User ID is MISSING from the database.</pre>';
    }
}

?>
```

```
switch ([조건변수]){
    case [비교값]:
      [소스 코드];
    case [비교값]:
      [소스 코드];
       .
       .
       .
    default :
      [소스 코드];
  }
```

```
$val;
 switch($val){
    case "남학생": echo "val은 남학생입니다.";
    case "남자": echo "val은 남자입니다.";
    case "사람": echo "val은 사람입니다.";
 }
```

```
$val;
 switch($val){
    case "php": echo "val은 php입니다."; break;
    case "asp": echo "val은 asp입니다."; break;
    default : echo "val은 php도 asp도 아닙니다."; break;
 }
```

try/catch

- 예외(또는 에러)를 처리하는 구문
- 프로그램 실행 중에 발생하는 예외상황을 감지하고 이에 대한 적절한 조치를 취할 수 있게 해 줌
- 예외 처리를 통해 프로그램의 안정성을 높이고 예측 할 수 없는 상황에 대응 할 수 있기 때문
- try 구문 안의 발생하는 오류를 throw 를 이용하여 정의하고 catch 구문에서 처리하는 형태로 구성

mysqli_query($GLOBALS["___mysqli_ston"])

- MySQL에 연결하기 위해 사용되는 함수
- mysqli_query($GLOBALS["___mysqli_ston"], "USE " . $_DVWA['db_database']) 함수를 사용하여 MySQL에 연결

```php
<?php
try
{
  if ($user_info['level'] != 1) throw new Exception('글쓰기 권한이 없습니다', 0);
  if (!isset($_POST['subject'])) throw new Exception('제목을 입력해주세요.', 1);
  if (!isset($_POST['contents'])) throw new Exception('내용을 입력해주세요.', 2);
  if (!mysqli_query($dbh, $sql)) throw new Exception('입력 실패하였습니다.', 3);
}
catch(Exception $e)
{
   switch ($e->getCode())
   {
      case 0: echo($e->getMessage()); break;
      case 1: echo($e->getMessage()); break;
      case 2: echo($e->getMessage()); break;
      case 3: echo($e->getMessage()); break;
   }
}
```

try 안에서 throw가 실행되면 그 자체로 코드 실행을 멈추고
catch 문으로 점프하기 때문에 데이터 무결성에도 좋음

```
if ($user_info['level'] != 1)
{
    if ($_POST['subject'])
    {
        if (isset($_POST['contents']))
        {
            if (mysqli_query($dbh, $sql))
            {
                echo("성공적으로 입력 되었습니다.");
            }
            else echo("입력 실패 하였습니다.");
        }
         else echo("내용을 입력하여 주세요.");
                }
                else echo("제목을 입력하여 주세요.");
}
else echo("글쓰기 권한이 없습니다.");
```

- **함수 isset( )**

  - 변수가 존재하지만 null이 아닌지 확인하는 함수

  - null과 그 외 값으로 구분할 수 있음

  - set 상태인 값이 true 아닌 값(null) 값은 false를 반환

```php
$var1 = '';
$var2 = null;

var_dump(isset($var1)); // true
var_dump(isset($var2)); // false
```

- $_COOKIE

  - 쿠키 값 출력

쿠키 memberID가 있는지 isset() 함수를 사용해 확인
쿠키가 있다면 쿠키값을 출력,
쿠키가 없을 때는 else의 문장을 출력

```php
<?php
  if (isset($_COOKIE['memberID'])) {
    echo "쿠키 memberID의 값은 " . $_COOKIE['memberID'];
  } else {
    echo "쿠키 memberID가 존재하지 않습니다.";
  }
?>
```

- $GLOBALS
  - 함수 안에서 전역 변수를 사용하는 방법
  - 사용하고 싶은 전역 변수가 $data라면 함수 안에서 $GLOBALS['data']와 같이 변수명을 키로 사용해 $data의 내용을 참조, 할당

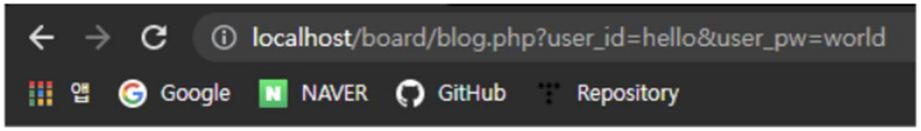
```php
<?php
// 전역 변수
$data = 5;
function scope_test(){
    // 전역 변수를 참조
    $GLOBALS['data'] += 1;
    print $GLOBALS['data'];
    print "<BR>";
}
print $data;
print "<BR>";
scope_test();
print $data;
print "<BR>";
?>
```

미리 정의된 변수

변수	의미
$GLOBALS	전역 변수
$_SEVER	서버 변수
$_ENV	환경 변수
$_COOKIE	HTTP 쿠키
$_GET	HTTP GET 변수
$_POST	HTTP POST 변수
$_FILES	HTTP 파일 업로드 변수
$_REQUEST	HTTP Request 변수
$_SESSION	Session 변수

- $_get
  - get 방식으로 데이터를 전송할 때는 url에 데이터를 포함

```php
<?php
echo $_GET['id'].','.$_GET['password'];
?>
```



hello,world

select * FROM 테이블명 LIMIT 숫자;

- 지정한 갯수 만큼의 자료만 보여줌
- LIMIT 구문은 결과에서 몇 개의 행을 반환할 것인지 제한

ID	NAME	AGE
1	Alice	20
2	James	22
3	Kelly	21
4	Selly	23
5	Jane	25

```
SELECT * FROM INFO LIMIT 1;
```

ID	NAME	AGE
1	Alice	20

```
SELECT * FROM INFO LIMIT 2, 3;
```

ID	NAME	AGE
3	Kelly	21
4	Selly	23
5	Jane	25